

보안 취약점 스캔 리포트

대상: http://test-server.local | 스캔일: 2026-07-02 | 생성일시: 2026-07-11 12:49 | 총 9건

4

Critical

3

High

1

Medium

1

Low

SQL Injection

Critical

/login

설명

로그인 폼이 사용자 입력값을 검증 없이 SQL 쿼리에 직접 삽입하여, 공격자가 임의의 쿼리를 실행할 수 있음

증거 (EVIDENCE)

payload: ' or 1=1 -- 입력 시 인증 우회되어 로그인 성공

대응 방안

Prepared Statement(파라미터바인딩) 사용, ORM 사용 권장

File Upload

Critical

/upload

설명

파일 업로드 기능이 확장자 검증을 하지 않아, 실행 가능한 스크립트 파일이 서버에 업로드될 수 있음

증거 (EVIDENCE)

shell.php 파일을 업로드 후 직접 접근하여 임의 명령 실행 확인

대응 방안

확장자 화이트리스트 검증, 업로드 파일 실행 권한 제거, 별도 스토리지 분리

Broken Authentication

Critical

/login

설명

인증 로직에 무차별 대입 공격 방지 장치가 없고, 세션 관리가 취약하여 계정 탈취 위험이 있음

증거 (EVIDENCE)

로그인 실패 횟수 제한 없음, 세션 토큰이 추측 가능한 패턴으로 발급됨

대응 방안

로그인 시도 횟수 제한, 세션 토큰 무작위성 강화, MFA 도입

Missing JWT Verification

Critical

/api/posts

설명

API 서버가 JWT의 서명을 검증하지 않아, 토큰을 임의로 조작해 인증을 우회할 수 있음

증거 (EVIDENCE)

서명이 변조된 JWT 토큰으로 요청해도 정상적으로 인증 통과됨

대응 방안

서명 검증 필수화, 토큰 만료시간 설정, Secret Key 안전하게 관리

Stored XSS

High

/board/write

설명

게시판 글 작성 시 입력값 검증이 없어, 악성 스크립트가 DB에 저장되고 모든 열람자에게 실행됨

증거 (EVIDENCE)

게시글 본문에 작성 후 저장, 게시글 조회 시 다른 사용자에게도 실행됨

대응 방안

입력값 검증 + 출력 인코딩 + CSP(Content Security Policy) 적용

Directory Traversal

High

/download?file=../../etc/passwd

설명

파일 다운로드 기능이 경로 검증 없이 사용자 입력을 그대로 사용하여, 서버 내 임의 파일에 접근 가능

증거 (EVIDENCE)

../.. 경로 조작으로 시스템 파일(/etc/passwd) 내용 노출 확인

대응 방안

경로 입력값 검증, 파일 접근을 화이트리스트 기반으로 제한

IDOR

High

/api/users/{id}

설명

API가 요청자의 권한을 검증하지 않고 객체 ID만으로 데이터를 반환하여, 타 사용자 정보에 무단 접근 가능

증거 (EVIDENCE)

본인 계정(id=5)이 아닌 다른 사용자(id=6)의 정보를 URL 변경만으로 조회 성공

대응 방안

요청자 권한과 객체 소유자 일치 여부 서버단에서 검증

Reflected XSS

Medium

/search

설명

검색 기능이 사용자 입력을 이스케이프 처리 없이 HTML에 그대로 반영하여, 악성 스크립트가 실행될 수 있음

증거 (EVIDENCE)

입력 시 검색 결과 페이지에 스크립트가 그대로 출력됨

대응 방안

출력 시 HTML Output Encoding 적용

Missing Rate Limiting

Low

/api/login

설명

로그인 API에 요청 횟수 제한이 없어, 무차별 대입 공격이나 서비스 거부 공격에 취약함

증거 (EVIDENCE)

1초당 100회 이상 로그인 요청을 보내도 차단되지 않음

대응 방안

API Gateway 또는 미들웨어 레벨에서 요청 횟수 제한 적용